

Email & Communication Security Policy

Mail authentication, phishing defense, and safe communications (PR, DE.CM)

Document ID: BVT-POL-039

Version: 1.0

Issued: July 02, 2026

Effective Date: _____

Purpose, Scope, and Authority

This policy is part of the BVTech Written Information Security Program, aligned to the NIST Cybersecurity Framework (CSF) 2.0. It applies to all BVTech LLC personnel, contractors, systems, and, where adopted by a client, the client's covered environment. The Managing Partner (or designated security officer) owns this policy, reviews it at least annually, and approves exceptions in writing. Violations may result in disciplinary action up to termination of employment or contract.

Exception process: submit written request describing the business need, compensating controls, and duration. Exceptions expire after 12 months unless renewed. NIST CSF 2.0 references shown per section (GV, ID, PR, DE, RS, RC).

Technical Controls

- Mail authentication enforced on all managed domains: SPF (-all where feasible), DKIM signing, DMARC at quarantine or reject with monitoring.
- Advanced email security in front of mailboxes: anti-phish, impersonation protection, link rewriting/detonation, attachment sandboxing where licensed.
- External-sender banners enabled; auto-forwarding to external addresses blocked by default.
- Legacy authentication (IMAP/POP basic auth) disabled tenant-wide.

User Rules

- Verify payment-change, gift-card, and urgent-wire requests by phone to a known number before acting — no exceptions, including requests appearing to come from executives.
- Report suspicious messages via the report button or service desk; do not forward live phish to coworkers.
- Do not send Restricted data (credentials, full SSNs, card numbers) via email; use approved secure sharing.
- Business communications occur on business platforms; auto-deleting consumer apps are not approved for business records.

Monitoring and Response

Email security telemetry is monitored; confirmed phishing triggers tenant-wide purge of the campaign, block-listing, and — for any user who entered credentials — immediate password reset, session revocation, and the BEC playbook (BVT-IRP-047).